

Module 3: Compliance Standards and PII Handling

Specific Controls, Frameworks, and Compliance Standards

- **NIST (National Institute of Standards and Technology):** A U.S.-based agency that develops voluntary compliance frameworks like the Cybersecurity Framework (CSF) and Risk Management Framework (RMF) to help organizations manage risk [cite: image_f7be5a.png].
- **FERC-NERC (Federal Energy Regulatory Commission - North American Electric Reliability Corporation):** A regulation for organizations involved with the U.S. and North American power grid, requiring them to prepare for, mitigate, and report security incidents, and adhere to Critical Infrastructure Protection (CIP) Reliability Standards [cite: image_f7be5a.png].
- **FedRAMP (Federal Risk and Authorization Management Program):** A U.S. federal government program that standardizes security assessment, authorization, monitoring, and handling of cloud services for government use [cite: image_f7be5a.png].
- **CIS (Center for Internet Security):** A nonprofit that provides controls to safeguard systems and networks against attacks and offers actionable steps for security incident response [cite: image_f7be5a.png].
- **GDPR (General Data Protection Regulation):** An E.U. regulation protecting the processing of E.U. residents' data and their right to privacy, requiring transparency and timely breach notifications [cite: image_f7be5a.png].

Handling PII

- Organizations must be deliberate about how PII is handled, where it is stored, and ensure constant awareness of its storage location [cite: image_f7c146.png].
- Protecting PII is often necessary to comply with various regulations and laws, and understanding these obligations is crucial [cite: image_f7c146.png].

Consequences of Non-Compliance

- Failure to meet PII obligations can lead to government regulators investigating a company's data handling practices [cite: image_f7c146.png].
- Customers and businesses may directly inquire about a company's data handling, impacting customer relationships, especially with sensitive data [cite: image_f7c146.png].

- Legal action is a common consequence, with victims of cybersecurity incidents increasingly suing companies for mishandling their data [cite: image_f7c146.png].

Staying Informed and Seeking Advice

- To stay updated on PII compliance, regulations, and laws, consult relevant government websites in the applicable jurisdiction [cite: image_f7c146.png].
- Given the complexity of PII laws globally, it is essential to seek advice from legal counsel for specific questions in a particular jurisdiction [cite: image_f7c146.png].